



סקירת אבטחה ומוכנות לפרודקשן

דוח ממצאים מלא ותוכנית טיפול · אתר, מובייל, API ובסיס נתונים

⚠ לא מוכן לעלייה – מוכן עם תיקונים (1-2 שבועות עבודה ממוקדת)

תאריך הסקירה: 11.06.2026 · גרסת מערכת: v0.13.9

היקף: 70 נקודות קצה · 72 API מודלי DB · אפליקציית iOS · סקריפטים · היסטוריית Git מלאה (392 קומיטים)

מתודולוגיה: 11 פאזות בדיקה · 7 תחומי סקירה מקבילים · כל ממצא אומת מול הקוד בפועל (קובץ:שורה)

1. תקציר מנהלים

בוצעה סקירת עומק (read-only) של פלטפורמת StatsAI לקראת עלייה לפרודקשן: ארכיטקטורה, הזדהות והרשאות, אבטחת API, בסיס נתונים, פרונטאנד, אפליקציית מובייל, סודות, תלויות, לוגים ולוגיקת הסטטיסטיקות עצמה.

השורה התחתונה: יסודות האבטחה הקלאסיים חזקים באופן יוצא דופן לפרויקט בסדר הגודל הזה - אין דליפת סודות, אין XSS, אין IDOR, וכל ממשקי האדמין מוגנים בצד השרת. מה שחוסם עלייה הוא **שלמות נתונים ותפעול**: באג חמור שמשחית סטטיסטיקות שחקנים, מחיקה שקטה של נתונים ממוזגים, היעדר גיבויים, וארכיטקטורת דפים שמחשבת 26 שנות נתונים בכל בקשה.

19

נמוכה / אינפורמטיבי

16

חומרה בינונית

12

חומרה גבוהה

4

ממצאים קריטיים

מה שנמצא חזק (לשמר) ✓

- **הזדהות:** bcrypt(12), טוקני ששן אקראיים נשמרים כ-hash בלבד, ביטול כל השנים בשינוי סיסמה, refresh-rotation עם זיהוי שימוש חוזר (family revocation).
- **הרשאות:** כל 21 נתיבי האדמין אומתו - בדיקת role בצד השרת. אפס IDOR. אפס mass-assignment (רשימות שדות מפורשות בכל עדכון).
- **סודות:** היסטוריית Git נקייה לחלוטין (392 קומיטים נסרקו) - אף מפתח אמיתי לא הוזרק מעולם. CI כולל סריקת סודות ל-bundle המובייל.
- **XSS:** אפס שימוש מסוכן ב-HTML - כל תוכן דינמי (חדשות טלגרם, תשובות AI, שמות מ-scraping) מרונדר כטקסט מוגן React.
- **מובייל:** ארכיטקטורת טוקנים מדויקת - refresh ב-Keychain בלבד, access בזיכרון בלבד, ATS מלא, אפס לוגים רגישים.
- **ארכיטקטורת מיזוג:** מודל rollback → execute → approve → preview → staging הוא העיצוב הנכון; הפערים בביצוע, לא בתפיסה.

2. ארבעת הממצאים הקריטיים – פירוט

C-1 • עריכת אירוע משחק משחיתה סטטיסטיקות קריירה **CRITICAL**

מיקום: src/app/api/events/route.ts:21-45

הפונקציה buildStatDelta מחזירה { goals: 1 } (ערך מוחלט) במקום Prisma - { goals: { increment: 1 } } מציב 1 במקום להוסיף 1. חמור מכך: ה-where הוא { playerId } בלבד, ללא עונה/מסגרת - כלומר העדכון פוגע בכל שורות הסטטיסטיקה של השחקן, בכל העונות.

משמעות: הוספת שער אחד דרך עורך המשחקים מאפסת מלך שערים היסטורי ל-1 שער בכל עונה. מחיקת אירוע מציבה 1-. כל עריכת אירוע מאז שהקוד עלה גרמה נזק שקט.

טיפול: (1) תיקון ל-increment + צמצום ה-where לעונה ולמסגרת של המשחק. (2) ביקורת נזק: SELECT * FROM player_statistics WHERE goals < 0 + השוואה מול מקורות הגלם ושחזור. מאמץ: 10~ שורות קוד + חצי יום ביקורת נזק.

C-2 • משיכת שחקנים חוזרת מוחקת שחקנים ממוזגים וכל הסטטיסטיקות שלהם **CRITICAL**

מיקום: src/app/api/admin/fetch/route.ts:1636-1661

בסוף סנכרון שחקנים מ-API-Football רץ player.deleteMany שמוחק כל שחקן עם apiFootballId = null ששמו האנגלי אינו ברשימת ה-API. שחקנים שנוצרו ממיזוג IFA מקבלים שם עברי בשדה nameEn - הם לעולם לא ברשימה, ולכן נמחקים יחד עם הסטטיסטיקות שלהם (cascade). עיקרון "מיזוג לא מוחק לעולם" נשבר במסלול ה-fetch.

משמעות: פעולת אדמין שגרית (רענון גל) משמידה בשקט נתונים סרוקים שאין להם תחליף.

טיפול: צמצום המחיקה לשחקנים עם apiFootballId ≠ null בלבד, או תיוג מקור (source) לכל שחקן. מאמץ: 5~ שורות.

C-3 • אין גיבויים אוטומטיים **CRITICAL**

מיקום: אין - זו הבעיה. נבדקו crontab , scripts/ ותיעוד הפרסה.

26 עונות של נתונים (~13K משחקים, ~208K הרכבים, ~122K אירועים) שעלות שחזורם היא חודשי scraping - קיימים בעותק יחיד על דיסק יחיד בשרת יחיד. הייצוא הידני מהאדמין אינו תחליף.

טיפול: cron לילי: pg_dump -Fc → רוטציה 7/30 יום → עותק מחוץ לשרת (Hetzner Storage Box / S3). לבצע תרגול שחזור אחד. מאמץ: ~שעה.

C-4 • ייבוא DB מהאדמין: מחיקת הכל לפני שחזור, ללא רשת ביטחון **CRITICAL**

מיקום: src/app/api/admin/db-transfer/route.ts:113-140

הייבוא מוחק את כל הטבלאות (DROP CASCADE, שגיאות נבלעות) ואז משחזר. כשל זיהוי שגיאות (רק "FATAL" ב-stderr נחשב כישלון), הקובץ כולו נטען לזיכרון ללא הגבלת גודל (סכנת OOM על שרת 3GB = השבתה באמצע DROP), וקובץ פגום משמיד את ה-DB ללא דרך חזרה.

טיפול: snapshot אוטומטי לפני DROP, בדיקת גודל קובץ, שחזור לסכמה זמנית והחלפה אוטומית, כשל על exit code. מאמץ: חצי יום.

3. ממצאים בחומרה גבוהה

#	ממצא	פירוט ומיקום	טיפול
H-1	עקיפת הגנת CSRF	בדיקת Origin עם <code>https://hbs.co.il/evil.com</code> - <code>startsWith</code> - <code>src/middleware.ts:59</code> עובר.	השוואת origin מדויקת מול רשימה קבועה (שורה אחת)
H-2	משחקים כפולים בין מקורות	<code>fetch</code> מזהה כפילות לפי תאריך מדויק; <code>merge</code> לפי חלון ± 24 ש'. כפילויות כבר קיימות בפרודקשן (workaround בדף הבית). <code>fetch/route.ts:1783</code> , <code>merge-engine.ts:615</code>	חלון תאריכים גם ב- <code>fetch</code> + דה-דופ + <code>constraint</code>
H-3	עריכת תוצאה לא מעדכנת טבלה	עדכון תוצאת משחק לא מחשב מחדש <code>Standing</code> / סטטיסטיקות. אין פונקציית <code>recompute</code> בכלל. <code>games/route.ts:188-295</code>	<code>recompute</code> לשורות המושפעות בכל שינוי תוצאה
H-4	מנוע מיזוג: TOCTOU + הרצה כפולה	<code>execute</code> משחזר <code>preview</code> ישן בלי אימות מחדש; בדיקת סטטוס לא אטומית - שני אדמינים = כפילויות. <code>merge-engine.ts:718</code> , <code>merge/route.ts:66</code>	אימות ערכי <code>old</code> בזמן <code>execute</code> + נעילת CAS על הסטטוס
H-5	rollback מוחק יותר מדי	מחיקת <code>Season/Team</code> שנוצרו במיזוג גוררת <code>cascade</code> על נתונים שנוספו אחר-כך ממקורות אחרים; כשלים נספרים כהצלחה. <code>merge-engine.ts:1112</code>	סירוב למחוק ישויות שצברו ילדים אחרי המיזוג
H-6	דפים ציבוריים כבדים ללא cache	<code>force-dynamic</code> על דף הבית, טבלאות, סטטיסטיקות והיסטוריה (שם <code>revalidate</code> נדרס בשקט) - חישוב 26 עונות בכל בקשה, על תהליך <code>pm2</code> יחיד	הסרת <code>force-dynamic</code> + <code>unstable_cache</code> לאגרגציות
H-7	אינדקסים חסרים	<code>Game.homeTeamId/awayTeamId/dateTime/status</code> , <code>GameEvent.playerId/type</code> (122K שורות) - סריקות מלאות בכל דף קבוצה/שחקן	6 שורות <code>index@@</code> בסכמה (~15 דקות)
H-8	עבודות ארוכות בתוך בקשת HTTP	<code>fetch</code> מלא (דקות) רץ בתוך <code>pm2 restart</code> ; <code>POST</code> באמצע = עבודה תקועה <code>RUNNING</code> לנצח + נתוני עונה חלקיים. <code>fetch/route.ts:782-3273</code>	סימון עבודות ישנות ככושלות באתחול; בהמשך - <code>job runner</code>
H-9	<code>execSync</code> מקפיא את האתר	<code>setup</code> מלא (90 דק') חוסם את ה- <code>event-loop</code> - האתר כולו קפוא. <code>setup-runner.ts:47-53</code>	מעבר ל- <code>spawn</code> אסינכרוני
H-10	בליעת שגיאות בכתיבות	<code>catch(() => null)</code> . על השקות עבודות רקע, יצירת אירועים במיזוג ו- <code>rollback</code> - כשלים נעלמים בלי לוג	לתפוס P2002 בלבד; לוג + ספירה לכל השאר
H-11	מפתחות AI בטקסט גלוי ב-DB	מפתחות <code>Claude/OpenAI</code> נשמרים ב- <code>plaintext</code> ב- <code>SiteSetting</code> - דולפים בכל ייצוא <code>ai-settings.ts:44-50</code> DB.	הצפנה (AES-GCM) מפתח <code>env</code> או מעבר ל- <code>env</code>
H-12	Rate-limit ניתן לזיוף (דורש אימות ידני)	המפתח נגזר מ- <code>x-forwarded-for</code> שהלוקו שולט בו אם <code>nginx</code> לא דורס אותו - עוקף הגנת <code>brute-force</code> בלוגין. <code>rate-limit.ts:25</code>	לודא <code>proxy_set_header X-Forwarded-For \$remote_addr</code> ב- <code>nginx</code>

4. עיקרי הממצאים בחומרה בינונית

#	ממצא	מיקום
M-1	הרשמה חברתית (Google/Apple) עוקפת את <code>REGISTRATION_DISABLED</code>	<code>social-auth.ts:99-109</code>
M-2	<code>Standing</code> ייחודי לפי (עונה, קבוצה) בלבד - מסגרת שנייה דורסת (כבר נתקלנו ב-P2002 במיזוג)	<code>schema.prisma:542</code>
M-3	<code>PlayerStatistics</code> עם <code>competitionId=NULL</code> - ייחודיות לא נאכפת, סיכון ספירה כפולה	<code>schema.prisma:592</code> , <code>merge-engine.ts:774</code>

games/route.ts:52-92	api/games / ציבורי ללא הגבלה - שליפת ~13K משחקים עם includes בכל בקשה	M-4
media-storage.ts:16,148	העלאת SVG מותרת (אדמין) - וקטור ה-XSS היחיד שנמצא	M-5
merge-engine.ts:45-73	התאמת שחקנים עמומה מדי (≤ 2 Levenshtein על שמות משפחה עבריים, 20K שחקנים)	M-6
teams/[id]/page.tsx:239	זהות מועדון = שם עברי מדויק - קבוצות ששינו שם מפוצלות בהיסטוריה	M-7
queryClient.ts:16 , AuthContext.tsx:66	מובייל: cache שאילתות נשמר ב-AsyncStorage כולל פרטי משתמש; logout לא מנקה אותו	M-8
package.json	תלויות מתות עם חולשות: axios, next-auth, i18next*3, html2canvas, jsPDF - אפס imports	M-9
next.config.js:14-19	בלוק api: {} מת ב-next.config - אין בפועל הגבלת גודל בקשה ב-route handlers	M-10
src/lib/activity.ts	לוגינג ביטחוני כמעט אפסי - 4 קריאות logActivity בלבד; אין לוג לכניסות כושלות/מחיקות/ייבוא	M-11
api/search/route.ts:13-57	חיפוש ציבורי ב-ILIKE ללא אינדקס 4 - trigram סריקות מלאות בכל הקלדה	M-12

5. תוכנית טיפול – ארבעה שלבים

שלב 0 · עצירת הנזק – היום-מחר (יום עבודה אחד)

1. **C-1**: תיקון באג ה-increment בעריכת אירועים + צמצום ה-where (10 שורות)
2. **C-1**: ביקורת נזק: שאילתת $goals < 0$ + השוואה מול מקורות ושחזור ערכים
3. **C-2**: צמצום מחיקת השחקנים ב-fetch לשחקני API בלבד (5 שורות)
4. **C-3**: cron גיבוי לילי + עותק מחוץ לשרת + תרגול שחזור
5. **H-1**: תיקון השוואת ה-Origin (שורה אחת)
6. **H-12**: אימות תצורת X-Forwarded-For ב-nginx
7. **M-1**: הוספת בדיקת REGISTRATION_DISABLED גם להרשמה חברתית + אימות שהדגל פעיל בפרודקשן

שלב 1 · חוסמי עלייה – שבוע עבודה

1. **C-4**: חיזוק db-transfer: snapshot לפני DROP, הגבלת גודל, כשל על exit code
2. **H-7**: הוספת 6 אינדקסים חסרים (Game, GameEvent)
3. **H-6**: caching: לדפים הציבוריים הכבדים (הסרת force-dynamic, unstable_cache לדף הבית ולהיסטוריה)
4. **H-2**: דה-דופליקציה של משחקים קיימים + התאמת חלון תאריכים ב-fetch
5. **H-3**: פונקציית recompute לטבלה בעת עריכת תוצאה
6. **H-11**: הצפנת מפתחות ה-AI ב-DB
7. **H-8**: sweeper באתחול לעבודות RUNNING תקועות
8. **Quick wins (מקבץ של 2~ שעות)**: באג פילטר OR בדף משחקים · הסרת בלוק api מת · הסרת 8 תלויות מתות · חסימת SVG בהעלאות · guard ל-queryRawUnsafe · לוג במקום בליעה בהשקות רקע · בדיקת https ב-openURL במובייל · הודעות שגיאה גנריות

שלב 2 · התקשרות ועמידות – שבוע-שבועיים

1. **H-4/H-5**: מנוע המיזוג: אימות מחודש ב-execute, נעילת CAS, rollback בטוח, דיווח כשלים אמיתי
2. **H-9**: החלפת execSync ב-spawn אסינכרוני (setup לא מקפיא את האתר)
3. **H-10**: טיפול שגיאות ממוקד (P2002 בלבד) בכל מסלולי הכתיבה
4. **M-2/M-3**: תיקון מפתחות ייחודיות: Standing+competitionId, ביטול NULL ב-PlayerStatistics
5. **M-4/M-12**: הגבלות pagination ל-API ציבורי + אינדקסי pg_trgm לחיפוש
6. **M-11**: Sentry/pino + הרחבת audit log (כניסות כושלות, מחיקות, ייבוא, מיזוגים)
7. **M-8**: מובייל (לפני הגשה ל-App Store): סינון ה-persister + ניקוי cache ב-logout

שלב 3 · אחרי העלייה – שיפור מתמשך

- איחוד לוגיקת התאמת השמות (3 עותקים) למודול משותף אחד – כבר גרם לבאג פעם אחת
- פיצול ה-route fetch (3,277 שורות) למודולים; job runner אמיתי לעבודות ארוכות
- טבלת זהות מועדונים (alias) לקבוצות ששינו שם; הרצת קישור קנוני אוטומטית אחרי מיזוג
- ביטול תוקף access tokens בעת (tokenVersion) logout-all
- חתימת קוד ל-OTA updates במובייל (EAS code signing)
- next/image לתמונות (26 קבצים עם img רגיל), שדרוג bcrypt→bcrypt/argon2

6. ציקליסט עלייה לאוויר

פריט	✓
כל פריטי שלב 0 + שלב 1 סגורים	☐
ביקורת הנזק של C-1 הושלמה והערכים שוחזרו	☐
תרגול שחזור מגיבוי בוצע בהצלחה (גיבוי שלא שוחזר ≠ גיבוי)	☐
תצורת nginx אומתה: X-Forwarded-For נדרס ע"י השרת	☐
REGISTRATION_DISABLED=true מאומת בפרודקשן (כולל מסלול חברתי)	☐
רוטציית מפתחות (API-Football, FootyStats, Firecrawl) API - נקיים בגיט אך ותיקים בסביבה	☐
רוטציית לוגים ב-pm2 + התראת שטח דיסק	☐
בדיקות עומס בסיסיות על דף הבית והטבלאות אחרי ה-caching	☐

7. בדיקות שמומלץ להוסיף

- 1. בדיקות golden-file ל- matchTeamName / normalizeName - מפת הקיצורים היא תשתית קריטית לשלמות הנתונים
- 2. בדיקת round-trip למנוע המיזוג: rollback → execute → preview על נתוני fixture, כולל תרחיש "DB השתנה בין preview ל-execute"
- 3. בדיקת נכונות stat-delta ב-API האירועים - assertion אחד היה תופס את C-1
- 4. מיון טבלה: pointsAdjustment + קבוצות פלייאוף
- 5. אידמפוטנטיות fetch: אותה עונה פעמיים → אפס שורות חדשות
- 6. מטריצת CSRF ב-origin: middleware מדויק, התקפת prefix, origin חסר
- 7. מובייל: logout מנקה cache; ה-persister לא שומר שאילתות עם נתוני משתמש

8. החלטה: Go / No-Go

NO-GO כרגע - אך ורק בגלל C-1 עד C-4 (השחתת נתונים פעילה + היעדר רשת ביטחון). מדובר בימים, לא בחודשים: תיקון C-1 הוא 10~ שורות, C-2 ~5 שורות, גיבויים - cron אחד.

הארכיטקטורה עצמה - staging→preview→rollback, סטטיסטיקות בצד שרת, auth נקי - היא היסוד הנכון ואינה דורשת בנייה מחדש. עם סגירת שלב 0 ושלב 1: GO.